— numéro 035 —

L'Oracle du Matin

PRIX · UN CAFÉ · ÉDITION DU MATIN · 035

✦ CE QUE DEMAIN NOUS RÉSERVE, LU CE MATIN ✦

ÉDITION DU MATIN
Mardi 3 novembre 2026
QUATRE COLONNES · DEUX PAGES

LE CHIFFRE DU JOUR

120 000 $

prix de vente de DuckMath, un site de...

LE MOT DU JOUR

Brownout

n. m. — définition en page 2.

DANS CE NUMÉRO

2 Irritant — Votre abonnement iPhone peut augmenter sans que vous disiez oui
2 Étude — Maddox, 21 ans : un site vendu 120 000 $, puis une appli qui n'avance pas assez vite
2 Outil — GitHub Actions bloquera pull_request_target par défaut le 2 décembre
2 Tech — Vercel refuse d'installer les versions npm connues pour être piégées
1 Tech — Vercel se configure aussi en TOML, avec des commentaires

☞ À LA UNE · IA

OPENAI A RÉÉCRIT LE SERVEUR GIT DE SON MONOREPO POUR TENIR LE RYTHME DE CODEX

Pando accepte les pushs sur des branches différentes en parallèle, sans changer le client Git de personne.

EXCLUSIF

Le 2 novembre, OpenAI a décrit Pando, un nouveau backend pour dépôts Git qui alimente désormais tout le développement de son monorepo. La raison : Codex permet à chaque ingénieur de mener bien plus de travaux en parallèle, donc plus de branches, de pushs, de fusions et de clones. Depuis la fin de l'an dernier, les systèmes en place peinaient : fetchs et pushs lents, fusions en échec, fiabilité parfois sous 90 %.

Le principe tient en deux choix. Les mises à jour de branches sans rapport avancent en parallèle au lieu de faire la queue derrière un point de coordination unique. Et le serveur réutilise les mêmes fichiers de paquets (le format de compression de Git) pour de nombreux clients, au lieu d'en fabriquer un par client. Le prix à payer, que le billet assume : un lecteur qui regarde plusieurs branches peut les voir à des instants différents.

Résultat annoncé : une latence médiane des pushs divisée par près de 5, et près d'un pétaoctet de données Git servi par jour. Le protocole et le client Git restent inchangés, si bien que les ingénieurs comme les agents n'ont rien à modifier.

Pour un développeur, la leçon est moins le produit, que l'on ne peut pas installer, que le constat : quand des agents poussent du code en rafale, c'est le serveur Git qui devient le goulot. OpenAI dit aussi vouloir proposer ses améliorations du client Git à la version officielle.

TECH ÉCLAIR

VERCEL SE CONFIGURE AUSSI EN TOML, AVEC DES COMMENTAIRES

Annoncé le 2 novembre : un projet Vercel peut utiliser un fichier *vercel.toml*, avec les mêmes propriétés que *vercel.json*, une structure plus plate et des commentaires. Un seul fichier de configuration par projet : vercel.toml, vercel.json ou vercel.ts.

LE LAB VOUS RÉPOND

L'énigme

On me coupe deux heures, deux fois, pour vous avertir que je disparaîtrai bientôt. Qui suis-je ?

Réponse : un brownout

L'IRRITANT DU JOUR

VOTRE ABONNEMENT IPHONE PEUT AUGMENTER SANS QUE VOUS DISIEZ OUI

Sous un certain seuil, Apple prévient par message, puis renouvelle au nouveau prix.

Selon la documentation qu'Apple destine aux développeurs, la hausse d'un abonnement ne demande l'accord de l'abonné que si elle dépasse 50 % du prix actuel **et** que la différence dépasse environ 5 $ par période (50 $ pour un abonnement annuel). En France : 5 € et 50 €. Deux autres cas : l'abonné a déjà subi une hausse dans les 12 derniers mois, ou il vit en Autriche, en Allemagne, en Pologne ou en Corée du Sud, où l'accord est toujours exigé.

Tout le reste passe en simple information : un e-mail et une notification, 27 jours avant le renouvellement d'un abonnement mensuel. Si vous ne faites rien, l'abonnement se renouvelle au nouveau prix. Ainsi, 4 € qui passent à 7 € (+75 %) restent sous la barre des 5 € de différence : aucun accord requis.

Quand l'accord est requis et que l'abonné ne répond pas, Apple relance environ chaque semaine, puis l'abonnement s'arrête à la fin du cycle en cours.

PISTE DE BUSINESS

Un suivi des hausses d'abonnements pour les particuliers : il lit les e-mails d'Apple et signale chaque hausse « sans accord », avec la somme annuelle en plus. Concurrence : les messages d'Apple et les gestionnaires d'abonnements existants.

L'ÉTUDE DE CAS

MADDOX, 21 ANS : UN SITE VENDU 120 000 $, PUIS UNE APPLI QUI N'AVANCE PAS ASSEZ VITE

Un fondateur solo qui s'est fixé une date limite, et qui la raconte avec ses chiffres.

Vers 16-17 ans, Maddox Schmidlkofer lance un site de jeux en ligne, DuckMath. Les premiers revenus publicitaires sont de 5 à 10 $ par jour. À la fin de l'été, le site rapporte environ 1 000 $ par jour. Vendu 120 000 $ en novembre 2025, après une offre initiale de 100 000 $ et une contre-proposition.

Son projet suivant, Tallow, est une appli qui scanne aliments et produits pour détailler leurs ingrédients. Démarrée le 1er mai 2026, en freemium, avec un plan payant d'environ 40 $ par an, elle rapportait moins de 2 000 $ par mois au moment de l'entretien publié le 7 octobre. L'objectif de 4 000 $ par mois, visé pour la fin août, n'était pas atteint ; la nouvelle échéance était le 31 octobre.

À retenir : un bon produit ne suffit pas sans distribution, et une appli ajoute des frictions qu'un site financé par la pub n'a pas (téléchargement, validation par Apple, mesure moins fine des conversions). Réserve : chiffres déclarés par le fondateur ; on ignore si l'échéance du 31 octobre a été tenue.

OUTIL OU ASTUCE DEV

GITHUB ACTIONS BLOQUERA PULL_REQUEST_TARGET PAR DÉFAUT LE 2 DÉCEMBRE

Deux coupures de test les 9 et 16 novembre : un workflow public peut s'arrêter ce jour-là.

Le 2 novembre, GitHub a annoncé que le déclencheur *pull_request_target* sera bloqué par défaut dans tous les dépôts publics à partir du 2 décembre, sauf autorisation explicite par une politique d'événements Actions. L'échéance était d'abord fixée au 2 novembre. Les dépôts privés et internes ne sont pas concernés, ni GitHub Enterprise Server.

La raison donnée : ce déclencheur s'exécute dans le contexte du dépôt de base et peut accéder à ses secrets, donc du code non fiable venu d'un fork peut compromettre la chaîne de livraison ou voler des secrets.

Deux fenêtres de test, de 16 h à 18 h UTC, les **9 et 16 novembre** : les exécutions bloquées échouent avec une annotation et ne démarrent pas. Entre les deux, les workflows tournent avec des avertissements. À faire avant le 9 : ouvrir *Insights* pour voir quelles exécutions seraient bloquées, puis décider de laisser bloquer ou d'autoriser des fichiers de workflow précis.

LA TECH

VERCEL REFUSE D'INSTALLER LES VERSIONS NPM CONNUES POUR ÊTRE PIÉGÉES

Le 2 novembre, Vercel a annoncé qu'il bloque des versions précises de paquets npm figurant sur une liste de blocage pour malware ou faille. Le contrôle a lieu avant l'installation, dans les lockfiles pris en charge, y compris quand les dépendances reviennent du cache de build, et pendant le téléchargement depuis le registre public.

C'est automatique sur tous les plans, sans réglage, pour les nouveaux builds. Si une dépendance bloquée est détectée, le déploiement échoue en nommant le paquet et la version, et Vercel tente d'invalider le cache concerné. Correction : passer à une version sûre, mettre à jour le lockfile, redéployer.

L'ŒIL DU BUSINESS

Un build qui échoue sans prévenir l'équipe est une alerte ratée : il y a un besoin de messages qui expliquent la correction à qui n'a pas écrit le code.

LE MOT

Brownout, *n. m.* : Coupure volontaire et temporaire d'une fonction qu'on va supprimer, pour que les utilisateurs encore dépendants la voient casser quelques heures et réagissent avant la date définitive.

LE MINI-DÉFI

En moins de 30 minutes : dans un de vos dépôts, lancez *grep -rl pull_request_target .github/workflows*. Si un fichier apparaît, notez ce qu'il fait avec les secrets du dépôt et décidez avant le 9 novembre : bloquer ou autoriser.

CARNET DU LECTEUR — UN IRRITANT CROISÉ AUJOURD'HUI, UNE IDÉE :

L'Oracle du Matin — journal du matin rédigé et composé par Claude pour 1977 Éditions, sur une idée de Michael Misran.
Sources : openai.com · developer.apple.com · nichepursuits.com · github.blog · vercel.com